

Incident Response and Legal Compliance: Final Report

Executive Summary:

This report presents the development and testing of an Incident Response Plan (IRP) integrated with legal and regulatory compliance requirements. Through four structured weeks, we mapped compliance needs, developed a tailored IRP, and tested its effectiveness via a ransomware tabletop exercise. Key insights and improvements have enhanced our cybersecurity resilience.

1. Introduction

This project aimed to build a robust IRP that aligns with key legal and regulatory frameworks. The process covered:

- Week 1: Legal and Regulatory Landscape.
- Week 2: Incident Response Plan Development.
- Week 3: Tabletop Exercise Execution.
- Week 4: Finalization and Presentation.

2. Legal and Regulatory Framework

We identified critical compliance requirements:

- GDPR (EU): 72-hour breach notification mandate.
- HIPAA/HITECH (US): 60 days to notify affected individuals.
- DORA (EU Financial Sector): 24-hour reporting deadline.
- SEC Disclosure Rules (US Public Companies): Report material incidents within 4 business days.
- Other frameworks: ISO 27001, NIST SP 800-61.

These regulations emphasize rapid detection, reporting, and evidence preservation.

3. Incident Response Plan (IRP)

Our IRP outlines:

- Phases: Preparation, Identification, Containment, Eradication, Recovery, and Lessons Learned.
- Roles: Clear duties for Incident Response Team Manager, Security Analysts, Legal Advisors, Forensics, and Communications.
- Compliance: Integrated regulatory requirements, including breach notifications and forensic processes.

4. Tabletop Exercise: LockBit Ransomware Simulation

- Scenario: A LockBit ransomware attack on Fawry's testing environment.
- Goals: Test detection, response, communication, and compliance readiness.
- Phases Covered:
 - Detection & Identification.
 - Containment & Isolation.
 - Eradication & System Cleaning.
 - Recovery & System Validation.

- Lessons Learned.

Key metrics included detection speed, containment efficiency, communication clarity, and recovery success.

5. Findings & Improvements

The exercise showed:

- Strengths: Fast detection and isolation of affected systems.
- Gaps: Some delays in internal communications and legal notification tracking.
- Improvements: Enhanced notification templates, stricter evidence preservation protocols, and updated role assignments.

6. Lessons Learned

- Cross-functional collaboration is critical for success.

- Compliance processes need continuous monitoring to meet strict deadlines.
- Regular tabletop exercises improve preparedness.

7. Recommendations

- Schedule quarterly tabletop exercises with realistic scenarios.
- Regularly review and update the IRP in line with evolving laws.
- Provide ongoing training for all stakeholders.
- Improve monitoring tools to ensure early detection.